

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking COURSE CODE: ITA1407

COURSE OUTCOME COVERED

CO3: Analyze network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min Total Marks: 50

1. Identifying and Prioritizing Vulnerabilities After Discovering Open Ports

After a port scan, I would first identify which services are running on each open port using service/version detection. For example, port 22 may indicate SSH, port 21 FTP, port 80 HTTP, and port 3306 MySQL.

I would then:

1. Identify the service and version running on each port.
2. Check whether the service is necessary for the system's business purpose.
3. Determine whether the service is exposed to the Internet or only to trusted networks.
4. Check for known vulnerabilities associated with the detected software/version using authorized vulnerability databases and scanners.
5. Assess the risk based on severity, exploitability, exposure, and business impact.
6. Prioritize critical vulnerabilities first, followed by high, medium, and low-risk issues.

For example, an outdated Internet-facing database service would normally receive a higher priority than an outdated internal service because its attack surface and potential impact are greater.

2. SYN Scan vs TCP Connect Scan Producing Different Results

A SYN scan (**-sS**) sends a SYN packet and analyzes the response without completing the TCP connection. A TCP Connect scan (**-sT**) completes the full TCP three-way handshake.

Different results can occur because of:

- Firewalls or IDS/IPS treating SYN packets differently from completed connections.
- Network filtering blocking or modifying specific packets.
- Rate limiting or temporary blocking of repeated scans.
- Application behavior changing depending on how the connection is established.
- Different scanning privileges—SYN scanning generally requires appropriate privileges, while TCP Connect can be used when raw-packet access is unavailable.
- Network instability or packet loss.

To verify the findings, I would repeat the scans under controlled conditions and compare the results. I could also perform **service/version detection**, inspect firewall or IDS logs if authorized, and manually test the relevant service ports. Nmap options such as **-sS**, **-sT**, and **-sV** can help confirm whether a port is genuinely open and what service is responding.

3. Most Ports Appear as "Filtered"

A filtered port means Nmap cannot determine whether the port is open because packets are being blocked or dropped.

Possible security mechanisms include:

- Firewalls
- Network Access Control Lists (ACLs)
- Cloud security groups
- IDS/IPS systems
- Host-based firewalls
- VPN or network segmentation

- Packet filtering by the ISP or network infrastructure

To gather additional information during an authorized assessment, I would:

1. Compare results using different scan types such as TCP SYN and TCP Connect.
2. Perform UDP scanning to identify services that do not use TCP.
3. Use service/version detection where ports respond.
4. Check whether filtering behaves differently across different network paths or interfaces.
5. Review firewall and IDS/IPS logs if access is available.
6. Use appropriate Nmap timing and packet-response analysis carefully to distinguish filtering from packet loss.

The goal is to determine whether the ports are actually closed, intentionally filtered, or simply unreachable because of network conditions.

4. Comparison of TCP, UDP, and Stealth (SYN) Scanning

Scan Type	How it works	Best scenario	Advantages	Limitations
TCP Connect	Completes the TCP three-way handshake	When raw-packet privileges are unavailable	Reliable and simple	More detectable because a complete connection is established
UDP Scan	Sends UDP probes and analyzes responses	Finding DNS, SNMP, DHCP and other UDP services	Detects services that TCP scans miss	Usually slower and UDP responses may be ambiguous

SYN/Stealth Scan	Sends SYN and analyzes the response without completing the connection	General TCP reconnaissance during authorized testing	Fast, efficient, and usually produces less application-level logging	Requires appropriate privileges and can still be detected by security systems
-------------------------	---	--	--	---

TCP Connect Scan

A TCP Connect scan is useful when the tester cannot perform raw-packet operations. Its main advantage is reliability, but completing connections can generate more logs and alerts.

UDP Scan

UDP scanning is important because many network services operate over UDP. However, UDP scanning can be slower because many UDP services do not respond directly to unexpected packets.

SYN/Stealth Scan

A SYN scan is commonly used for TCP port discovery because it does not complete the full TCP handshake. It provides good speed and efficiency, but "stealth" does not mean invisible—modern firewalls, IDS, and EDR systems can detect scanning activity.

5. Internet-Exposed SSH, FTP, and Database Services

I would first determine whether each exposed service is required for legitimate business operations and whether Internet exposure is actually necessary.

Risk Assessment

SSH (Port 22):

- Brute-force and credential attacks

- Password-based authentication risks
- Exploitation of outdated SSH software
- Unauthorized remote access if credentials are compromised

FTP (Port 21):

- Traditional FTP can transmit credentials and data without encryption.
- Anonymous or weak authentication can increase risk.
- It should generally be replaced with SFTP or another secure file-transfer mechanism where appropriate.

Database ports:

- Direct Internet exposure significantly increases the attack surface.
- Attackers may attempt credential attacks or exploit vulnerable database software.
- A compromised database could result in data theft, modification, or destruction.

Recommended Mitigations

1. Remove unnecessary services from Internet exposure.
2. Restrict access using firewalls, security groups, and IP allowlists.
3. Place databases on private/internal networks rather than exposing them directly to the Internet.
4. Keep operating systems and services patched and updated.
5. For SSH, prefer key-based authentication, disable unnecessary authentication methods, and restrict administrative access.
6. Replace insecure FTP with SFTP/FTPS, depending on organizational requirements.
7. Use strong passwords and multi-factor authentication where supported.
8. Apply least-privilege access controls.
9. Enable logging and monitor authentication and connection attempts.
10. Regularly perform vulnerability assessments and configuration reviews.

Conclusion

The main principle is reduce the attack surface. A service should be Internet-accessible only when there is a legitimate business requirement. Critical services such as databases should normally be isolated from direct Internet access, while administrative services such as SSH should be strongly restricted and monitored.

Code of Conduct:

I Lavanya K(192565025) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in

*disciplinary action. **Signature of the student:***